

Confusion pairs: the distinctions the exam actually tests

Forty pairs in seven tables, then eight scenarios – several of them deliberate reversals of ones you have already worked.

The exam rarely asks what a service does.
It asks **which of these two**, and the answer
is in the requirement.

Detection and logging

WHEN YOU NEED	IT IS	NOT
Who called an API, and when	CloudTrail	CloudWatch Logs
What a resource looked like on a date	Config resource timeline	CloudTrail
Behavioural threat detection	GuardDuty	Inspector
Known CVEs in an image or instance	Inspector	GuardDuty
Is there personal data in this bucket	Macie	Config
What is the story across these findings	Detective	Security Hub CSPM

ON THE EXAM

Config answers 'what is it', CloudTrail answers 'who changed it'. Both record change; only one records intent and identity.

Incident response

WHEN YOU NEED	IT IS	NOT
Prove the architecture survives failure	Fault Injection Service	Resilience Hub
Predict whether it will meet RTO and RPO	Resilience Hub	Fault Injection Service
Test the detection and response pipeline	GuardDuty sample findings	FIS
Stop the attack, keep the evidence	Isolate	Terminate
Kill an already-issued session	Deny on aws:TokenIssueTime	Deleting the access key

ON THE EXAM

FIS injects infrastructure faults. It does not simulate an attacker – which is why sample findings exist.

Network

WHEN YOU NEED	IT IS	NOT
Block one specific address range	Network ACL	Security group
Allow a tier without hardcoding IPs	Security group referencing	Prefix list
Stop the connection to a hardcoded IP	Network Firewall	DNS Firewall
Catch tunneling to unknown domains	DNS Firewall Advanced	A domain list
Prove no path exists	Network Access Analyzer	VPC Flow Logs
Prove nobody used a path	VPC Flow Logs	Network Access Analyzer

ON THE EXAM

Identity, subnet, packet, name. Most wrong answers here are the right idea applied at the wrong layer.

Edge and compute

WHEN YOU NEED	IT IS	NOT
S3 origin with SSE-KMS objects	Origin access control	Origin access identity
Stop bypass of CloudFront to an ALB	Prefix list and secret header	A web ACL on the ALB
Rate-limit a rotating botnet	JA3 or JA4 aggregation	Per-IP rate limiting
Shell access with a record of commands	Session Manager	EC2 Instance Connect
Stop a container reading the host role	Task roles, hop limit 1	Hop limit 2

ON THE EXAM

OAI cannot read SSE-KMS objects. That single fact decides most CloudFront origin questions.

Identity

WHEN YOU NEED	IT IS	NOT
Restrict a principal outside your org	Resource control policy	Service control policy
Delegate role creation safely	Permissions boundary	Session policy
Defend against a vendor confused deputy	sts:ExternalId	aws:SourceArn
Defend against a service confused deputy	aws:SourceArn	sts:ExternalId
An immutable record of which human	sts:SourceIdentity	RoleSessionName
The client calls AWS directly	Identity pool	User pool alone

ON THE EXAM

Ceilings intersect, grants union. Silence in a ceiling is a denial; silence in a grant just means the other grant carries it.

Data protection

WHEN YOU NEED	IT IS	NOT
Key material never inside AWS	External key store	Imported key material
Prove provenance of the key	Imported key material	External key store
Nobody deletes it, including root	Object Lock compliance mode	Governance mode
A break-glass path for deletion	Governance mode	Compliance mode
Automatic credential rotation	Secrets Manager	Parameter Store
Irreversible de-identification	Anonymisation	Masking or tokenisation

ON THE EXAM

Two mirrored pairs here. Each member is correct for its own requirement, and the requirement always names which.

Governance

WHEN YOU NEED	IT IS	NOT
Config that survives new AWS APIs	Declarative policy	SCP
Block provisioning before it exists	Proactive control	Detective control
Evidence about AWS itself	AWS Artifact	Audit Manager
Assess one workload, risk-rated	Well-Architected Tool	Security Hub CSPM
Score an account against a standard	Security Hub CSPM	Well-Architected Tool
Require a tag exists	SCP with Null	Tag policy

ON THE EXAM

Proactive controls only see CloudFormation. If the scenario deploys by CLI or Terraform, the answer is preventive.

Four phrases that decide questions

- ◆ **'Prevented rather than corrected'** eliminates every detective and remediation answer.
- ◆ **'Even if X changes'** or **'without maintaining a list'** points at the durable mechanism.
- ◆ **Absolutes** – 'including the root user', 'never enters AWS', 'directly from the device' – eliminate fastest.
- ◆ **'Not merely...'** means the obvious answer is the near miss. Read what follows it.
- ◆ Two options, same verdict? **Check which states the rule correctly.**

ON THE EXAM

Scan the requirement for the discriminating phrase before reading the options. It is usually one clause, and it is usually decisive.

An auditor asks a company to demonstrate what the inbound rules of a specific security group were on 14 March, three weeks before an incident. CloudTrail is enabled with an organization trail, and AWS Config is recording all resource types.

The engineer produces CloudTrail events showing AuthorizeSecurityGroupIngress calls, which the auditor says do not answer the question.

What should the engineer produce?

- ☐ A CloudTrail Lake query joining all security group API calls in that period
- ☐ Security Hub CSPM findings for that security group from that date
- ☐ The Config resource timeline, or GetResourceConfigHistory for that group
- ☐ VPC Flow Logs showing what traffic the group actually permitted

◆ PAUSE AND DECIDE

What should the engineer produce?

- A

A CloudTrail Lake query over the API calls

More of what the auditor rejected. You could reconstruct the state by replaying every call, which is inference rather than evidence.
- B

Security Hub CSPM findings

Reports whether the group violated a control, not what its rules were. A compliant group and a specific rule set are different statements.
- C

Config resource timeline or GetResourceConfigHistory

Correct. Config records configuration items - the actual state of the resource at each point in time, which is exactly what was asked.
- D

VPC Flow Logs

Records traffic that occurred. Traffic that did not occur says nothing about what the rules permitted.

THE SIGNAL

CloudTrail records the calls. Config records the resulting state. The auditor asked for state.

A company integrates a third-party monitoring vendor, which assumes a role in the company's account. It also configures an SNS topic that CloudTrail publishes delivery notifications to.

A reviewer says both configurations are vulnerable to the same class of attack and require different defences.

Which defence applies to which?

- | | |
|---|---|
| <p>A sts:ExternalId on the vendor role's trust policy;
aws:SourceArn on the SNS topic policy</p> | <p>B aws:SourceArn on the vendor role's trust policy;
sts:ExternalId on the SNS topic policy</p> |
| <p>C sts:ExternalId on both, generated by the
company</p> | <p>D aws:PrincipalOrgID on both, since neither
principal is in the organisation</p> |

◆ PAUSE AND DECIDE

Which defence applies to which?

- A

 ExternalId on the role; SourceArn on the topic
Correct. The deputy is a company in the first case and an AWS service in the second, and those take different controls in different policy types.
- B

 The two, swapped
Both controls are real and each is applied to the wrong deputy. SourceArn does not constrain a vendor's account; ExternalId is not an SNS policy condition.
- C

 ExternalId on both, company-generated
Two errors. ExternalId is an sts condition for role assumption, and the vendor generates the value, not the customer.
- D

 aws:PrincipalOrgID on both
CloudTrail is an AWS service belonging to no organisation, so the condition would never match and delivery would break entirely.

THE SIGNAL

Same attack, two deputies. The question is whether the deputy is a company you contracted or a service AWS runs.

During due diligence for an acquisition, the acquiring company's security team must state whether any principal outside the target's AWS Organization can reach three S3 buckets, and whether any network path exists from the internet to a set of database subnets.

The target has eight years of CloudTrail and two years of VPC Flow Logs, and offers both as evidence.

What should the team ask for instead?

- ☐ A Longer log retention, and Athena queries across both datasets
- ☐ B Security Hub CSPM findings for the buckets and subnets
- ☐ C GuardDuty findings history for the target's accounts
- ☐ D IAM Access Analyzer external access findings, and Network Access Analyzer scopes

◆ PAUSE AND DECIDE

What should the team ask for instead?

A More logs and Athena queries

More observation. Eight years of logs proves nobody used a path, which is a weaker claim than no path existing.

C GuardDuty findings history

Behavioural detection - again observation, and of attacks rather than of reachability.

B Security Hub CSPM findings

Scores configuration against a standard. A passing control is not a proof about every possible principal or every possible path.

D Access Analyzer external access findings and Network Access Analyzer scopes

Correct. Both use automated reasoning to prove statements about every possible request or path, which is what due diligence requires.

THE SIGNAL

Two questions, two analyzers, one property: automated reasoning proves, observation only records.

A role with AdministratorAccess receives AccessDenied on s3:GetObject. There is no SCP or RCP denying S3, no explicit Deny anywhere, and the bucket policy in the same account allows the role by ARN. The role has a permissions boundary allowing only ec2:* and logs:.*.

A second engineer, using an IAM user named directly in the same bucket policy and with no identity policy at all, can read the object.

Why does one succeed and the other fail?

- ☐ A The IAM user has an implicit allow from the bucket policy; roles never do
- ☐ B The role's boundary is silent on s3, and a resource policy naming a role ARN is limited by that implicit deny
- ☐ C The bucket policy is evaluated before the boundary for users but after it for roles
- ☐ D The role needs the boundary removed; boundaries always override resource policies

◆ PAUSE AND DECIDE

Why does one succeed and the other fail?

A Implicit allow for users, never for roles
There is no such thing as an implicit allow. The bucket policy grants explicitly in both cases; what differs is whether a ceiling's silence applies.

C Different evaluation order for users and roles
Evaluation order is the same. The difference is which principal is making the request - a role session rather than the role itself.

B The boundary is silent on s3, and a role ARN is limited by that implicit deny

Correct. A resource policy granting directly to an IAM user ignores an implicit deny in a boundary; one naming a role ARN does not.

D Boundaries always override resource policies
Right verdict for the role, false as a rule - and it cannot explain why the user succeeded, which the correct answer must.

THE SIGNAL

Same account, same bucket policy, opposite outcomes. The variable is user versus role ARN, and it is documented.

A team must store around 4,000 application configuration values – feature flags, endpoint URLs, timeouts and a handful of API keys for internal services that are rotated manually once a year by a documented process.

Cost is a stated concern. There is no requirement for automatic rotation, cross-Region replication, or cross-account access.

What should the team use?

- ☐ A Parameter Store, using SecureString for the API keys
- ☐ B Secrets Manager for everything, for consistency
- ☐ C Secrets Manager for the API keys, Parameter Store for the rest
- ☐ D Parameter Store advanced tier, for the higher parameter limit

◆ PAUSE AND DECIDE

What should the team use?

- A

Parameter Store with SecureString
Correct. SecureString encrypts with KMS exactly as Secrets Manager does, none of Secrets Manager's differentiators is required, and the standard tier is free up to 10,000 parameters.
- B

Secrets Manager for everything
Per-secret monthly charges for 4,000 values, buying rotation, replication and resource policies the requirement explicitly does not need.
- C

Split by type
The reflex answer – secrets go in Secrets Manager. Here it adds a second service and per-secret cost for keys rotated annually by hand.
- D

Advanced tier for the limit
4,000 is under the standard tier's 10,000, so the advanced tier's charges buy nothing this scenario asks for.

THE SIGNAL

The reversal: usually the answer is Secrets Manager. Here every reason to pay for it has been removed from the requirement.

A media company must retain raw footage for seven years and prevent accidental deletion by editors and automation. Its legal team requires that, if a court orders specific footage destroyed, a named compliance officer must be able to delete it before the retention period expires.

An engineer proposes S3 Object Lock in compliance mode with a seven-year retention period.

What should the company use?

- ☐ A Compliance mode as proposed, with a documented exception process
- ☐ B Versioning with MFA delete, restricted to the compliance officer
- ☐ C Governance mode, with s3:BypassGovernanceRetention granted only to the compliance officer
- ☐ D Compliance mode with a legal hold the compliance officer can remove

◆ PAUSE AND DECIDE

What should the company use?

- A

 Compliance mode with a documented process
A document cannot delete an object. In compliance mode nobody can, including the root user, so the court order could not be complied with.
- B

 Versioning with MFA delete
Protects against casual deletion and is not WORM. It also gives the compliance officer no more authority than anyone else with the MFA device.
- C

 Governance mode, bypass granted only to the compliance officer
Correct. Governance mode's documented bypass permission is precisely a controlled exception path, granted to exactly one named person.
- D

 Compliance mode plus a removable legal hold
Removing a legal hold does not shorten a retention period. The compliance-mode retention would still block deletion.

THE SIGNAL

The reversal: usually compliance mode wins. Here the requirement asks for an exception, and governance mode is the one that has one.

A company deploys all infrastructure with Terraform, not CloudFormation. It wants EBS volumes created without encryption to be impossible, not merely detected and remediated afterwards.

A platform engineer proposes activating a proactive control in Control Tower, having read that proactive controls block non-compliant resources before they are provisioned.

What should the company implement?

- ☐ A The proactive control as proposed; it evaluates all resource creation
- ☐ B A declarative policy or SCP, since proactive controls only evaluate CloudFormation
- ☐ C A detective control with SSM Automation remediation
- ☐ D cfn-guard in the Terraform pipeline

◆ PAUSE AND DECIDE

What should the company implement?

- A

 The proactive control as proposed
Proactive controls are CloudFormation hooks. This company deploys with Terraform, so every resource would be created without ever meeting the hook.
- B

 A declarative policy or SCP
Correct. Both operate at the API level regardless of the deployment tool – and a declarative policy for EBS encryption survives new EC2 APIs too.
- C

 Detective control with remediation
Corrective. The volume exists unencrypted until remediation runs, and EBS cannot be encrypted in place – it would need replacing.
- D

 cfn-guard in the pipeline
Genuinely validates Terraform JSON plans, and it is a pipeline check that a direct API call bypasses. The requirement says impossible.

THE SIGNAL

The reversal: proactive controls were right in module 32 because that company used CloudFormation. Here the deployment tool changes the answer.

A CISO must report quarterly to the board on how each of the company's 60 AWS accounts scores against CIS AWS Foundations Benchmark, with per-control status and a trend over time.

She is not assessing a particular workload, and she needs the same numbers produced the same way every quarter without a facilitated review.

What should she use?

- ☐ A A Well-Architected Tool review per account against the security pillar
- ☐ B Trusted Advisor security checks, exported quarterly
- ☐ C AWS Artifact's CIS attestation for each account
- ☐ D Security Hub CSPM with the CIS standard, via central configuration

◆ PAUSE AND DECIDE

What should she use?

A A Well-Architected review per account

Workload-scoped and facilitated, producing risk-rated findings rather than a repeatable score. Sixty reviews a quarter is also not a reporting process.

C Artifact's CIS attestation

Artifact holds AWS's own compliance documents. There is no per-account attestation about the customer's configuration.

B Trusted Advisor security checks

Shallow and not aligned to CIS. It flags issues without scoring against a named benchmark.

D Security Hub CSPM with the CIS standard, centrally configured

Correct. Account-scoped, scored against a named standard, per-control status, repeatable, and central configuration applies it across all 60 accounts.

THE SIGNAL

The reversal of scenario 4 in module 36: there the unit was a workload and no standard was wanted. Here it is accounts and a named standard.

Five things to carry forward

- ◆ **Both members of a pair are usually right for something.** The requirement names which.
- ◆ **Scan for the discriminating phrase before reading the options.** It is usually one clause.
- ◆ **Absolutes eliminate fastest** – including the root user, never enters AWS, directly from the device.
- ◆ **When two options share a verdict, check which states the rule correctly.**
- ◆ **Expect reversals.** The familiar answer to a familiar pair is only correct when the familiar requirement is present.

ON THE EXAM

Next: exam mechanics – ordering and matching questions, qualifiers, and how to spend 170 minutes.